

NERC CIP — Compliance Report

Cisco Secure Workload | IT-Side Mapping for the Bulk Electric System

Cisco Secure Workload — Compliance Mapping Series

Version 1.0 (draft — pending SME review)

Table of Contents

Cisco Secure Workload — NERC CIP Compliance Mapping

How to read this report

This report describes how Cisco Secure Workload (CSW) supports a Registered Entity's compliance posture against the NERC Critical Infrastructure Protection (CIP) Reliability Standards on the **IT side** of the IT/OT boundary.

Scope statement up front. CSW is a workload-protection and segmentation platform for IT estate — servers, virtual machines, containers, and cloud workloads. CSW does **not** enforce policy on PLCs, RTUs, relays, IEDs, HMIs, or any other Level 0–2 OT device. CSW's NERC CIP contribution is at the **IT-side of the ESP boundary and within the Electronic Access Control or Monitoring Systems (EACMS) and Physical Access Control Systems (PACS) supporting infrastructure** — jump hosts, identity/PKI servers, vendor-access hosts, patch repositories, engineering workstations, historian/MES databases, and the corporate IT systems that touch BES Cyber System Information (BCSI). For controls inside the ESP at the OT device layer, your ICS/SCADA security stack and your ESP-boundary firewall arrangement remain the controlling artefacts.

Companion document. The accompanying *NERC CIP Reference Design* walks through deployment, scoping, ESP-boundary design, IRA enforcement, CIP-007/010 evidence collection, and CIP-013 supply-chain visibility on the IT side. Read this report for the audit- narrative view; read the reference design for the deployment view.

How to read the Coverage column

Direct means Secure Workload produces the primary evidence artifact for that row — segmentation, policy, flow and process telemetry, inventory, vulnerability and reachability, or forensic reconstruction. Direct is still evidence, not an attestation.

Supporting means Secure Workload contributes an input that feeds or complements another control, tool, or process — detection input only, reconciled against an external register, or one log source among several.

Evidence Required means Secure Workload has no record for that row. The customer supplies the contract, the analysis, or the HR / physical-security evidence from another control.

Every report in this set now uses the same three coverage words — Direct, Supporting, and Evidence Required. Coverage describes what evidence Secure Workload produces; it never means the control is passed.

1. Executive Summary

NERC CIP cybersecurity requirements apply to Registered Entities operating the Bulk Electric System in North America. The standards have moved decisively since 2020 toward continuous evidence, automated configuration baselining, and supply-chain visibility — all areas where workload-level segmentation and telemetry produce materially better RSAW responses than network-firewall logs alone.

What CSW changes for a NERC CIP programme:

- **CIP-005 R1 IT-side hardening.** The ESP boundary firewall remains your EAP, but CSW enforces deny-by-default *up to* that boundary from the corporate IT side. The undocumented-pivot risk that has driven several past enforcement actions is structurally removed.
- **CIP-005 R2 Interactive Remote Access evidence.** Per-session flow attribution from the Intermediate System out to the BES Cyber Asset, retained for the audit window, with no forensic gaps.
- **CIP-007 R1 Ports and Services evidence.** Per-workload listening- port inventory with last-observed-flow timestamp, cross-referenced to the documented baseline, dated quarterly.
- **CIP-010 R1.5 Configuration Change Management.** Daily diff of installed software and listening ports, with disposition column tying back to your change-management ticketing system. Orphan changes (CSW-detected but ticket-absent) become unauthorised- change candidates.
- **CIP-010 R3 Vulnerability Assessments.** Continuous CVE inventory per workload with CVSS, exploit-availability, and EPSS context; cadence-based exports satisfy R3.1 active VA evidence for High- impact assets.
- **CIP-013 R1 Supply Chain Risk Management.** Vendor-egress observation against your vendor register, with allowlist enforcement on EACMS and immediate alerting on new external destinations.

What CSW does not change. CSW does not perform CIP-002 categorisation, does not act as an EAP, does not enforce on OT devices, and does not replace the CIP Senior Manager's accountability under CIP-003. It is the IT-side evidence engine that those governance artefacts depend on.

2. Compliance Posture Summary

The following table summarises CSW's contribution to each in-scope NERC CIP standard. Coverage is rated as:

- **Direct** — CSW is the primary technical control or evidence source for the requirement on the IT side.
- **Supporting** — CSW supplements another control with evidence or enforcement that strengthens the audit response.
- **Out of scope** — CSW does not address the requirement; relies on other parts of the cyber programme (HR, physical, governance, OT controls).

Standard	Topic	Coverage	CSW contribution
CIP-002	BES Cyber System Categorisation	Supporting	Inventory + scope labelling for CSW-managed workloads in the EACMS / PACS-supporting / BCSI-host tier; cross-reference to your CIP-002 register
CIP-003	Security Management Controls	Supporting	Quarterly evidence pack to the CIP Senior Manager covering CIP-005/007/010/013 IT-side outputs
CIP-004	Personnel & Training	Evidence Required	HR/training process
CIP-005 R1	Electronic Security Perimeter	Direct (IT-side)	Per-facility IT-side enclave segmentation; deny-by-default from corporate IT to EAP-IP set; documented exception list
CIP-005 R2	Interactive Remote Access	Direct (IT-side)	Intermediate-system enforcement; per-session flow telemetry; weekly IRA-pattern report
CIP-006	Physical Security	Evidence Required	Physical / PACS process
CIP-007 R1	Ports and Services	Direct	Per-workload listening-port inventory with last-

Standard	Topic	Coverage	CSW contribution
			flow timestamp; quarterly evidence pack
CIP-007 R2	Patch Management	Supporting	Continuous CVE inventory feeds the patch programme; CSW does not deploy patches
CIP-007 R3	Malicious Code Prevention	Direct (IT-side)	Behavioural rules + simulation → enforcement progression; layered with endpoint AV
CIP-007 R4	Security Event Monitoring	Direct (IT-side)	Process + flow telemetry to SIEM with documented retention
CIP-008	Incident Reporting and Response	Direct (evidence)	Six-artefact reconstruction bundle for every incident; supports E-ISAC notification under R4
CIP-009	Recovery Plans	Supporting	Policy and baseline export for DR; not the recovery executor itself
CIP-010 R1	Configuration Baseline	Direct	Daily software + listening-port baseline with diff and disposition
CIP-010 R3	Vulnerability Assessments	Direct	Continuous CVE inventory; cadence-based active-VA evidence for High-impact assets
CIP-011	Information Protection (BCSI)	Supporting	Egress and access pattern monitoring on BCSI-host workloads; layered with DLP and identity controls
CIP-013	Supply Chain Risk	Direct (technical)	Vendor-egress

Standard	Topic	Coverage	CSW contribution
	Management	lens)	observation, register reconciliation, EACMS allowlisting
CIP-014	Physical Security (transmission)	Evidence Required	Physical / CCTV scope

Posture takeaway. The table above is the programme-role view: Direct, Supporting, or out of scope. It leaves out CIP-007 R5 (system access control), CIP-012 (communications between Control Centers), and CIP-015 (internal network security monitoring). The Control Coverage Summary below is the evidence view for every in-scope requirement, including those three. Direct coverage is CIP-007 R1 and CIP-010 R1 on instrumented IT-side workloads. Supporting coverage is where Secure Workload supplies one slice and another control completes the requirement. Evidence Required, with no Secure Workload artifact, is CIP-004, CIP-006, and CIP-014.

Control Coverage Summary

Use this table when an auditor asks what Secure Workload can put in the evidence file for each requirement. The ratings apply to IT-side workloads in the agreed scope that have a reporting sensor. They are evidence contributions. They are not a finding that the Registered Entity is compliant, and they do not make Secure Workload an Electronic Access Point or an OT control.

Direct coverage. On instrumented IT-side workloads, export the artifact named in the row and file it against that requirement.

Supporting coverage. Secure Workload covers the slice in “What Secure Workload produces.” File that export next to the record in “What the entity still files.”

Evidence Required. Secure Workload does not produce the record. The entity files the document from the programme that owns it.

Standard	What Secure Workload produces	What the entity still files	Coverage
CIP-002	Labelled inventory (impact, BCS id, ESP membership) that mirrors the categorisation register.	The High, Medium, or Low decision against Attachment 1.	Supporting
CIP-003	Quarterly IT-side pack for the CIP Senior Manager: policy, ports, baseline, and vendor	The policies, the Senior Manager designation, and the delegations.	Supporting

	egress.		
CIP-004	No personnel record.	Background checks, training, and access revocation.	Evidence Required
CIP-005 R1	Deny-by-default from corporate IT up to the EAP address set, and the exception list.	The EAP firewall configuration. Secure Workload is not the Electronic Access Point.	Supporting
CIP-005 R2	Per-session flows from the Intermediate System for the audit window.	Session encryption and multi-factor authentication on the Intermediate System.	Supporting
CIP-006	No physical-security record.	The physical security perimeter, badge access, and visitor logs.	Evidence Required
CIP-007 R1	Listening-port inventory with the bound process and the last-flow time, dated at least quarterly.	Tie each listener to the documented baseline.	Direct
CIP-007 R2	CVE and package list for software installed on the workload.	The evaluation window, the patch source, and the install record. Secure Workload does not install the patch.	Supporting
CIP-007 R3	Behavioural-rule catalogue and the simulation-to-enforce record.	The endpoint anti-malware product and its logs.	Supporting
CIP-007 R4	Process and flow telemetry forwarded to the SIEM.	The alert procedure, the review log, and the retention attestation.	Supporting
CIP-007 R5	Policy that limits which workloads can reach the	Account inventory, passwords, and multi-	Supporting

	authentication services. This requirement was not in the posture table above.	factor authentication.	
CIP-008	Six-artefact reconstruction bundle for the incident window: flows, processes, policy verdicts, and hosts touched.	The response plan, the plan test, and the E-ISAC notification.	Supporting
CIP-009	Policy workspace and configuration baseline as a known-good IT-side state.	Backup execution and the recovery test.	Supporting
CIP-010 R1	Daily software and listening-port baseline, the diff, and a disposition against the change ticket.	The change ticket itself. A change seen here and absent from a ticket is the unauthorised-change candidate.	Direct
CIP-010 R3	Per-workload CVE inventory.	The entity's active assessment method, the cadence by impact rating, and the mitigation record.	Supporting
CIP-011	Egress and access-pattern report for hosts labelled as BCSI hosts.	Classification, storage, transit, and disposal of BES Cyber System Information.	Supporting
CIP-012	Observed paths, and an allowlist, for instrumented control-center workloads that exchange real-time assessment or monitoring data. This standard was not in the posture table	Identification of that real-time data, the protection method on the control-center link, and the CIP-012 plan. Secure Workload does not encrypt that link.	Supporting

	above.		
CIP-013	Vendor-egress flows reconciled to the vendor register, and the allowlist on electronic access systems.	The supply-chain risk plan and the vendor contract clauses.	Supporting
CIP-014	No physical-security record.	Transmission-station physical security.	Evidence Required
CIP-015	East-west flow and process telemetry on instrumented IT-side hosts, as an input to internal network security monitoring. Confirm the effective date for the entity's impact rating before an audit cites this row.	Monitoring on OT segments and on hosts with no sensor.	Supporting
CIP-007 R5 (system access control)	Policy restricting which workloads can reach authentication services	Authentication-path policy export, filed with the identity-system account and MFA evidence	
CIP-012 R1 (control-center communications)	Observed flows and an allowlist between instrumented control-center workloads that carry real-time data	Flow export and allowlist, filed with the CIP-012 plan and the link-protection record	
CIP-015 (internal network security monitoring)	East-west flow and process telemetry on instrumented IT-side hosts	Telemetry export for the monitored segment, after the entity confirms CIP-015 applies	

3. Mapping Table — NERC CIP Requirement → CSW Capability → Evidence Artefact

Requirement	CSW capability	Evidence artefact (audit-ready)
CIP-002 R1 (BCS identification)	Workload labelling: <code>bes_impact</code> , <code>bes_role</code> , <code>bcs_id</code> , <code>esp_member</code> , <code>facility</code>	Per-scope inventory CSV with workload identity, OS, owner, BCS reference, ESP membership flag, last-seen timestamp
CIP-005 R1.1 (ESP boundary documentation)	Per-facility policy workspace; documented exception list; deny-by-default to EAP-IP set	Workspace export per facility with simulation → enforcement transition log
CIP-005 R1.2 (ESP applicability)	Scope membership snapshot for each ESP	Dated CSV of every workload tagged <code>esp_member=true</code>
CIP-005 R1.5 (boundary control review)	Quarterly enforcement diff report	Diff PDF/CSV delivered to the CIP Senior Manager
CIP-005 R2 (Interactive Remote Access)	Intermediate-system enforcement policy; weekly IRA-flow report	Per-session flow telemetry export; IRA-pattern report dated within audit window
CIP-007 R1.1 (Ports and Services baseline)	Per-workload listening-port inventory with process attribution and last-flow timestamp	Quarterly listening-port inventory export per workload
CIP-007 R1.2 (CIP Exceptional Circumstances)	Documented exceptions in the workspace notes; flow-log evidence of exception usage	Exception register with CSW-observed enforcement evidence
CIP-007 R3 (Malicious Code Prevention)	Behavioural rule catalogue; simulation → enforce progression	Rule catalogue with last-modified dates and CIP coverage mapping
CIP-007 R4 (Security Event Monitoring)	Process + flow telemetry forwarded to SIEM with retention	SIEM forwarding configuration; sample alert with full forensic context
CIP-008 R1 (Incident response plan)	Standard six-artefact reconstruction bundle template	Sample dossier from the audit window
CIP-008 R2 (Implementation testing)	CSW-driven tabletop reachability queries	Pre/post reachability reports for each test
CIP-010 R1.1.1 (OS/firmware baseline)	Daily OS + kernel snapshot per workload	Baseline export dated to the period

Requirement	CSW capability	Evidence artefact (audit-ready)
CIP-010 R1.1.2–R1.1.3 (software baseline)	Daily package list snapshot per workload	Baseline export with package + version
CIP-010 R1.1.4 (network-accessible ports baseline)	Daily listening-port snapshot	Baseline export with port + bound process
CIP-010 R1.1.5 (security patches)	Continuous CVE inventory tied to package versions	CVE export with patch-applied-by date
CIP-010 R1.5 (unauthorised change monitoring)	Daily diff vs. previous day with disposition column	Diff log with authorised/unauthorised flag tied to change ticket
CIP-010 R3.1 (active vulnerability assessment)	Per-workload CVE list with CVSS, exploit availability, EPSS	Cadence-based export per impact rating
CIP-010 R3.2 (pre-commissioning VA)	First-sighting CVE inventory before ESP connection	Pre-commissioning VA report per new asset
CIP-011 R1.1 (BCSI access controls)	Egress and access pattern monitoring on <code>bes_role=bcsi-host</code> workloads	BCSI-host inventory + anomaly alert log with disposition
CIP-011 R1.2 (BCSI in third-party storage)	CSW Cloud Connector coverage of cloud BCSI targets	Cloud inventory + access pattern report
CIP-013 R1.2.5 (vendor remote access)	EACMS egress allowlist scoped to vendor register	Allowlist policy export + observed-vs-register delta
CIP-013 R1.2.6 (vendor incident coordination)	Vendor-egress flow record for any incident window	Per-incident vendor flow extract
CIP-012 link protection	Control-center communications owner	Identification of real-time data and protection of the control-center link. Secure Workload shows the path; it does not encrypt it.
CIP-015 on OT segments	OT/ICS team	Internal network security monitoring on segments with no Secure Workload sensor, including Level 0–2 networks.

4. Out-of-Scope and Complementary Controls

CSW does **not** address the following CIP requirements; reference the noted complementary controls.

Requirement	Owner	Complementary control
CIP-002 categorisation decision	CIP Senior Manager + Asset Owners	Risk + engineering analysis against Attachment 1 thresholds
CIP-003 governance	CIP Senior Manager	Programme charter, policy library, training records
CIP-004 personnel	HR + CIP Senior Manager	Background checks, role-based training, access reviews
CIP-005 EAP enforcement	Network/Firewall team	Boundary firewall pair (Cisco Firepower, Palo Alto, Fortinet, etc.)
CIP-006 physical security	Facilities + Physical Security	PSP enclosure, badge access, CCTV
CIP-007 R5 system access controls	Identity/PAM team	AD/LDAP, PAM (CyberArk, BeyondTrust), MFA
CIP-009 active recovery	Backup + DR team	Backup product, DR plan execution
CIP-014 transmission physical security	Physical Security	Site hardening, vehicle barriers, hardened control house
OT device-layer enforcement (PLCs, IEDs, HMIs)	OT/ICS team	OT-aware monitoring (Cyber Vision, Claroty, Nozomi, Dragos)
OT-protocol deep packet inspection (DNP3, IEC 61850, Modbus)	OT/ICS team	OT-aware sensors at the protocol layer

CSW's role in a complete NERC CIP programme is the IT-side segmentation, EACMS hardening, and continuous evidence engine. It explicitly defers the OT device-layer scope to the appropriate specialised stack and the governance / HR / physical scope to the appropriate owners.

5. Suggested Next Steps

For Registered Entities considering CSW within their NERC CIP programme:

1. **Confirm CIP-002 inputs.** Validate the BCS impact ratings and the EACMS / PACS-supporting / BCSI-host tier definition before starting CSW scope design. CSW labels mirror this taxonomy; bad inputs produce bad evidence.
 2. **Pilot on the EACMS tier first.** Jump hosts, vendor-access hosts, AD, PKI, and patch repositories give the highest-value wins (CIP-005 R1 IT-side, CIP-005 R2 IRA evidence, CIP-007 R1 ports inventory) with the lowest deployment friction.
 3. **Pair with the existing EAP firewall pair.** CSW does not replace the EAP. Position CSW as the IT-side hardening *up to* the EAP, with the EAP itself remaining the boundary control of record under CIP-005 R1.
 4. **Wire the CIP-010 R1.5 unauthorised-change feed into your ticketing system day one.** The orphan-change report is one of the most asked-for artefacts during RSAW evidence requests, and CSW produces it automatically.
 5. **Tie the CIP-013 vendor-egress allowlist to your supplier onboarding workflow.** Adding CSW allowlist updates as a step in vendor onboarding closes the most common audit gap (vendor endpoint observed but not in the register).
 6. **Plan SME review.** This document is a v1 mapping. Before being relied upon in a formal compliance engagement, route to a NERC CIP compliance specialist for regulatory accuracy and to a current Cisco Secure Workload SE for product-capability accuracy.
-

6. Disclaimer

This report and its companion reference design describe how Cisco Secure Workload capabilities can support a NERC CIP cybersecurity programme on the **IT side** of the IT/OT boundary. They are **not** legal or regulatory advice and do not constitute a finding of compliance.

Specifically:

- Final identification and categorisation of BES Cyber Systems (CIP-002), the design of ESP and EAP arrangements (CIP-005), determination of impact ratings (Attachment 1), CIP-008 reportable Cyber Security Incident decisions (R4), and the formal RSAW audit response remain the responsibility of the Registered Entity's CIP Senior Manager and qualified compliance counsel, working with the applicable Regional Entity (WECC, NPCC, RF, SERC, TRE, MRO).
- CSW does not enforce policy on PLCs, RTUs, IEDs, HMIs, or any other Level 0–2 OT device, and is not certified as an Electronic Access Point (EAP).
- Cisco product capabilities, NERC standards effective revisions, and Regional Entity audit guidance evolve. Always validate against the current effective revision of each CIP standard published on the NERC web site, against your Regional Entity's current audit guidance, and against any FERC orders amending applicability or compliance dates.

This document should receive subject-matter-expert review for both NERC CIP regulatory accuracy and current Cisco product capability before being used in a customer engagement.